



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



Rockwell Automation FactoryTalk Historian Site Edition

CVE / Vulnerability Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-06-18
Version	1.0
Author	Lost Boys Cyber
Report Type	CVE / Vulnerability Threat Intelligence Report

TLP:CLEAR | Lost Boys Cyber | Rockwell Automation FactoryTalk Historian Site Edition - CVE / Vulnerability Threat Intelligence Report

Published: 2026-06-18 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Vulnerability Metadata
3. Source Review & Confidence
4. Vulnerability Details
5. Attack Scenarios
6. Affected Products and Exposure
7. Aviation / Aerospace Sector Impact
8. Mitigation and Workarounds
9. Detection Engineering
 - 9.1. Detection Logic Summary
10. Threat Hunting
 - 10.1. Hunt Hypothesis
11. MITRE ATT&CK Mapping
12. Validation / Lab Testing
13. Recommended Actions Summary
14. References

Rockwell Automation FactoryTalk Historian Site Edition

1. Executive Summary

CISA ICSA-26-169-03 covers three vulnerabilities in Rockwell Automation FactoryTalk Historian Site Edition: CVE-2025-13036, CVE-2025-44019, and CVE-2025-36539. The highest-impact issue is an authentication-bypass condition in FactoryTalk Historian SE 11 where repeated login endpoint requests may obtain a valid authentication token.

Industrial historians are high-value OT systems because they aggregate production, facility, and process telemetry. In aviation and aerospace environments, historian data may support airport facilities, fuel systems, MRO facilities, environmental controls, production lines, and quality or test telemetry. Unauthorized access or denial-of-service can impair situational awareness even when it does not directly manipulate controllers.

2. Vulnerability Metadata

Field	Value
CVEs	CVE-2025-13036; CVE-2025-44019; CVE-2025-36539
Vendor / Product	Rockwell Automation FactoryTalk Historian Site Edition
Highest Severity	CVE-2025-13036 CVSS v4.0 9.2 Critical; CVSS v3.1 7.7 High per CISA
Weaknesses	Race condition / authentication bypass; uncaught exception denial-of-service
Affected Versions	FactoryTalk Historian SE 11 and <= 11.00 as scoped by each CVE
Primary Impact	Authentication token exposure, service crash, denial-of-service, possible data loss in snapshots/write cache
Exploitation Status	No active exploitation confirmed in reviewed sources

3. Source Review & Confidence

Source	Contribution	Confidence
CISA ICSA-26-169-03	CVE list, product scope, CVSS vectors, mitigations	High
Rockwell Automation SD1773	Vendor patch, best-practice, and workaround guidance	High when accessible to customers
CVE indexing sources	Independent index of CVE-2025-13036 description and scores	Medium

The vulnerability facts are sourced primarily from CISA and Rockwell. Exploitation status is assessed as unconfirmed because reviewed sources did not show confirmed in-the-wild exploitation.

4. Vulnerability Details

CVE-2025-13036 is an authentication-bypass condition: CISA reports that continually sending requests to the login endpoint may allow an attacker to obtain a valid authentication token. CVE-2025-44019 and CVE-2025-36539 affect AVEVA PI Data Archive components used in FactoryTalk Historian SE and can allow authenticated users to shut down important PI subsystems, causing denial-of-service and possible data loss depending on timing.

5. Attack Scenarios

Scenario	Preconditions	Result
Login endpoint abuse	Network path to Historian web/login endpoint	Attacker obtains token and accesses historian context
Authenticated PI subsystem crash	Valid low-privilege or compromised account	Loss of historian availability and possible snapshot/write-cache impact
Facility OT visibility degradation	Historian supports airport/MRO/manufacturing telemetry	Operators lose historical and near-real-time trend data during incident response

6. Affected Products and Exposure

Exposure Pattern	Why It Matters	Priority
Historian reachable from corporate IT or vendor VPN	Increases likelihood of token abuse after phishing/VPN compromise	Critical
Historian connected to airport/facilities OT	Impacts operational visibility for power, baggage, HVAC, fuel, production, or test cells	High
Segmented historian with strict allow-listing	Lower probability but still requires patch/workaround tracking	Medium

7. Aviation / Aerospace Sector Impact

Segment	Operational Relevance	Likely Exposure Path	Defender Action
Airports	Historian platforms may track facility OT, utilities, baggage, environmental, or fuel-system telemetry	Vendor remote support, engineering workstations, IT/OT firewall exceptions	Restrict historian endpoints and review token/auth logs
Aerospace manufacturing	Historians can support production quality, test stands, and utilities	Manufacturing execution and OT DMZ integrations	Patch or isolate Historian SE and monitor PI services
MRO / hangar facilities	Facility availability affects maintenance operations and safety compliance	Contractor support channels and facility-management systems	Validate backups, service restart policies, and network segmentation

8. Mitigation and Workarounds

1. Review Rockwell Automation advisory SD1773 and apply corrected versions or patch BF32850 where applicable.
2. Restrict TCP access to Historian/PI services, including port 5450, to trusted workstations and applications.
3. Monitor liveness of PI Network Manager and PI Archive Subsystem services and configure automatic restart where operationally appropriate.
4. Centralize authentication logs and alert on repeated login endpoint attempts.
5. Place historian endpoints behind an OT DMZ or jump host rather than exposing them directly to corporate or vendor networks.

9. Detection Engineering

9.1. Detection Logic Summary

Signal	Telemetry Source	Analytic Goal
High-rate login endpoint requests	Web, reverse proxy, EDR network logs	Detect CVE-2025-13036-style token abuse attempt
PI subsystem service crash/restart	Windows service logs, EDR, historian monitoring	Detect DoS activity tied to CVE-2025-44019 / CVE-2025-36539
Port 5450 connections from unexpected hosts	Firewall, Zeek, Windows Firewall	Identify unauthorized PI Data Archive access
<pre> title: FactoryTalk Historian Repeated Login Endpoint Requests status: experimental logsource: category: webserver detection: selection: cs-uri-stem contains: - /login - /auth timeframe: 5m condition: selection fields: - c-ip - cs-uri-stem - sc-status - user_agent level: high DeviceNetworkEvents where Timestamp > ago(14d) where RemotePort in (5450, 5457, 443, 80) where RemoteUrl has_any ("historian", "piwebapi", "factorytalk") or InitiatingProcessCommandLine has_any ("PI", "Historian", "FactoryTalk") summarize Connections=count(), FirstSeen=min(Timestamp), LastSeen=max(Timestamp) by DeviceName, LocalIP, RemoteIP, RemotePort, InitiatingProcessFileName where Connections > 50 </pre>		

10. Threat Hunting

10.1. Hunt Hypothesis

An attacker attempting token acquisition or denial-of-service against FactoryTalk Historian will generate abnormal login bursts, unexpected PI port connections, or service crash/restart patterns.

<pre> DeviceEvents where Timestamp > ago(30d) where ActionType has_any ("ServiceStopped", "ServiceStarted", "ServiceInstalled") where AdditionalFields has_any ("PI Network Manager", "PI Archive", "FactoryTalk", "Historian") project Timestamp, DeviceName, ActionType, AdditionalFields, InitiatingProcessAccountName </pre>

11. MITRE ATT&CK Mapping

Technique	Name	Evidence / Rationale
T1190	Exploit Public-Facing Application	Applies when Historian login interfaces are reachable from untrusted networks
T1078	Valid Accounts	Authenticated DoS CVEs require account

		access
T1499	Endpoint Denial of Service	PI subsystem shutdown creates denial-of-service

12. Validation / Lab Testing

No exploit reproduction was attempted. Validation completed: CISA advisory review, CVE corroboration search, content QA, and PDF text extraction after render.

13. Recommended Actions Summary

Priority	Owner	Action
Critical	OT owner	Identify all FactoryTalk Historian SE 11 / <=11 deployments
Critical	Network engineering	Restrict historian login and PI service ports to trusted management paths
High	Platform owner	Apply Rockwell patch / corrected versions or documented mitigations
High	SOC	Deploy login burst, service restart, and unexpected port 5450 detections

14. References

- [1] CISA ICSA-26-169-03: Rockwell Automation FactoryTalk Historian Site Edition
- [2] Rockwell Automation Security Advisory SD1773
- [3] CVE-2025-13036 vulnerability indexes